Университет ИТМО

Факультет программной инженерии и компьютерной техники
Образовательная программа
«Системное и прикладное программное обеспечение»

Курсовая работа
По дисциплине «Информационные системы»

Информационная система для поиска и возврата потерянных вещей «Потеряшки»

Этап 4

Выполнил студент группы [номер группы]
Евграфов Артём Андреевич

Проверил:
[ФИО преподавателя]

Санкт-Петербург 2026

Содержание

Задание четвёртого этапа..... 2
21. Уровень представления..... 2
22. Доступ и обработка данных.....15
23. Проверка веб-приложения.....17
24. Демонстрация и итоговые материалы..... 18
Источники четвёртого этапа..... 19

Задание четвёртого этапа

1. Реализовать уровень представления для бизнес-процессов первого этапа.

2. Сформировать итоговый отчёт, включающий предыдущие этапы.

3. Подготовить и представить проект.

21. Уровень представления

21.1. Технологии и структура

Веб-интерфейс реализован на Java 17, Spring MVC и Thymeleaf. Браузер получает готовые HTML-страницы; формы отправляют запросы на контроллеры приложения. Для оформления используется локальный файл CSS. Отдельная сборка frontend и прикладной JavaScript не требуются. Серверный вариант интерфейса сохраняет выбранный на предыдущих этапах стек Spring Boot, Hibernate/JPA, PostgreSQL, Lombok и Gradle.

Контроллеры сгруппированы по процессам: AccountPages обслуживает доступ к аккаунту; MainPages — личный кабинет, подписку, уведомления и справочник; ListingPages — каталог и объявления; ReturnPages — заявки и диалоги; AuctionPages — допуски, лоты и ставки; StaffPages — служебные операции. MediaPages выдаёт вложения после проверки полномочий. WebQueries формирует проекции для шаблонов без паролей, хешей токенов и закрытых примет чужих вещей.

Контроллер передаёт идентификатор участника из проверенного WebIdentity. Идентификатор действующего пользователя не принимается из формы. Предметные операции выполняют существующие сервисы третьего этапа. Поиск, резервирование, подтверждение передачи, активация подписки, ставка и завершение торгов продолжают использовать функции и процедуры PostgreSQL второго этапа.

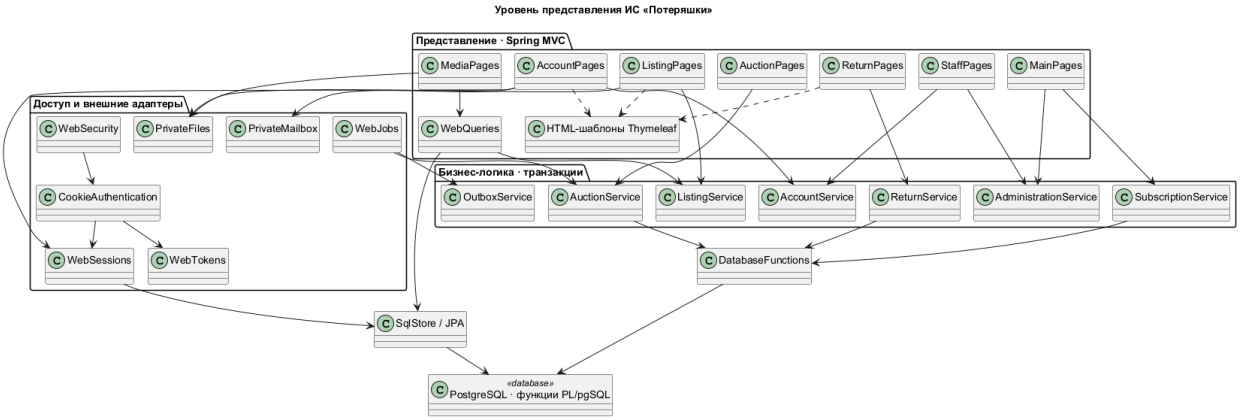


Рисунок 15 — Архитектура уровня представления

21.2. Страницы и прецеденты

Таблица 24 — Соответствие интерфейса прецедентам

Прецедент	**Страница и действие**
UC-01. Получить доступ	Участник: /auth/register, /auth/confirm, /account, /subscriptions; модератор: очередь профилей /staff; оплата и доступ к каталогу. Вход и восстановление — /auth/login, /auth/forgot, /auth/reset
UC-02. Опубликовать объявление	Автор: /listings/new, фото, закрытые приметы и отправка; модератор: /staff?tab=listings, просмотр и решение; другие участники: опубликованная карточка
UC-03. Вернуть вещь	Владелец: /catalog, карточка и заявка; нашедший: /claims, проверка и резерв; обе стороны: /conversations/{id} и два подтверждения. Хранитель-организация — инструкция /metro
UC-04. Разрешить спор	Участник: жалоба из карточки или диалога и решение в кабинете; модератор: очередь жалоб, доступные материалы и служебное решение
UC-05. Продать вещь	Продавец: допуск и лот /auctions; модератор: проверка основания; покупатели: /auctions/{id}, ставки; WebJobs: итог; продавец и победитель: /claims и подтверждения
UC-06. Изменить полномочия	Администратор: роли в /admin; сотрудник: доступ либо отказ на служебной странице после изменения; история — /staff?tab=audit
UC-07. Актуализировать инструкцию	Администратор: организация в /admin; участник: обновлённые контакты, источник и дата на /metro
UC-08. Изменить тариф	Администратор: создание и закрытие тарифа в /admin; участник: новые условия заказа в /subscriptions; старые заказы сохраняют цену

Регистрация и личный кабинет доступны до подписки. Для каталога, публикации и участия в торгах нужны подтверждённая почта, проверенный

профиль и действующая подписка. Чтение собственного диалога и завершение согласованной передачи сохраняются после окончания оплаченного периода. Служебные операции требуют роли модератора или администратора.

21.3. Организация интерфейса

Главная страница объясняет порядок возврата вещи и открывает поиск либо создание объявления. Основная навигация содержит каталог, инструкцию метро и личный кабинет. Для авторизованного пользователя боковое меню показывает объявления, заявки, подписку и письма. Служебные пункты появляются при соответствующей роли.

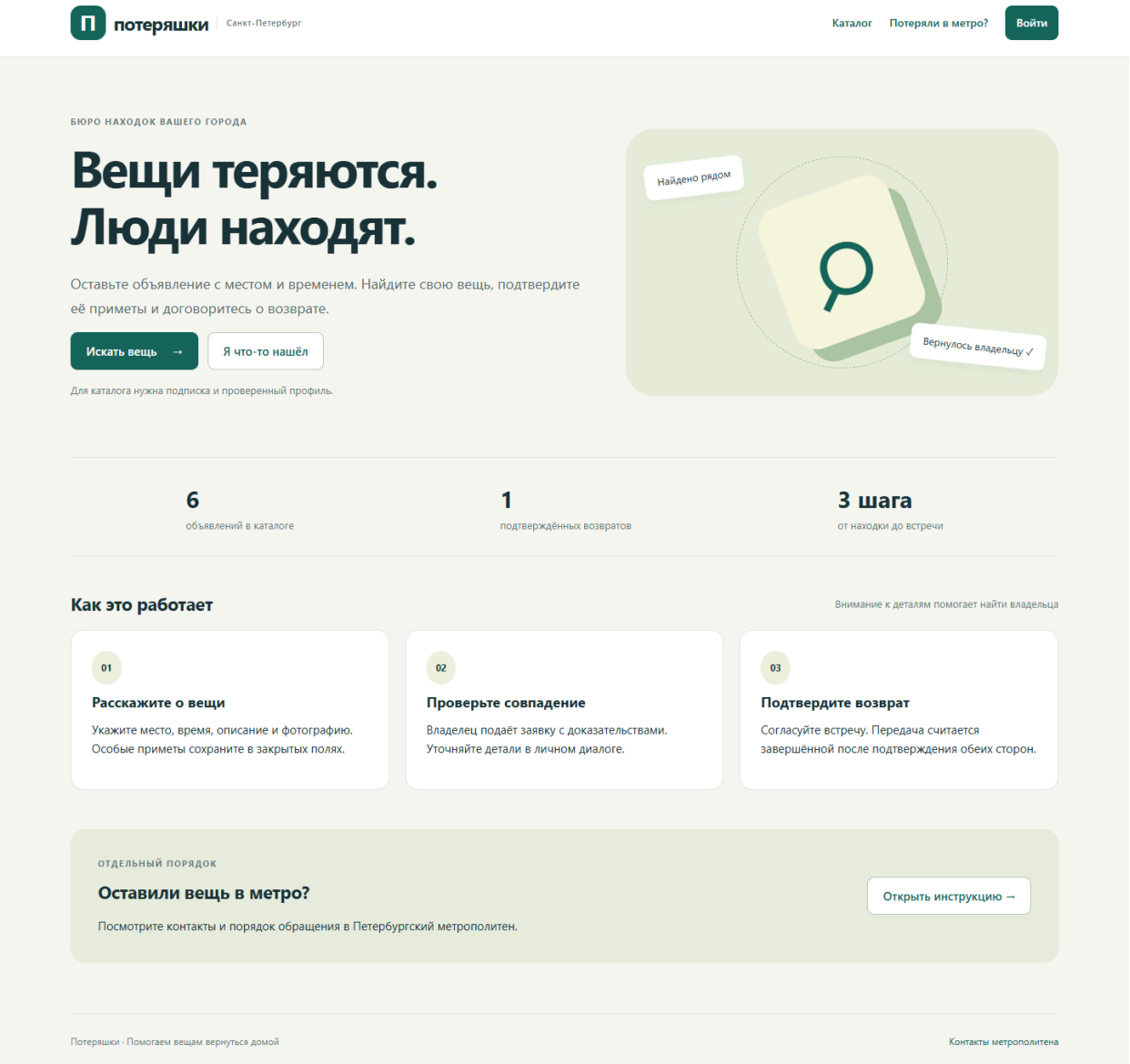


Рисунок 16 — Главная страница

В каталоге фильтры передаются параметрами GET, поэтому результат можно открыть по сохранённой ссылке. Следующая страница использует идентификатор последней записи как курсор и сохраняет фильтры. При отсутствии совпадений выводится пояснение с предложением изменить условия.

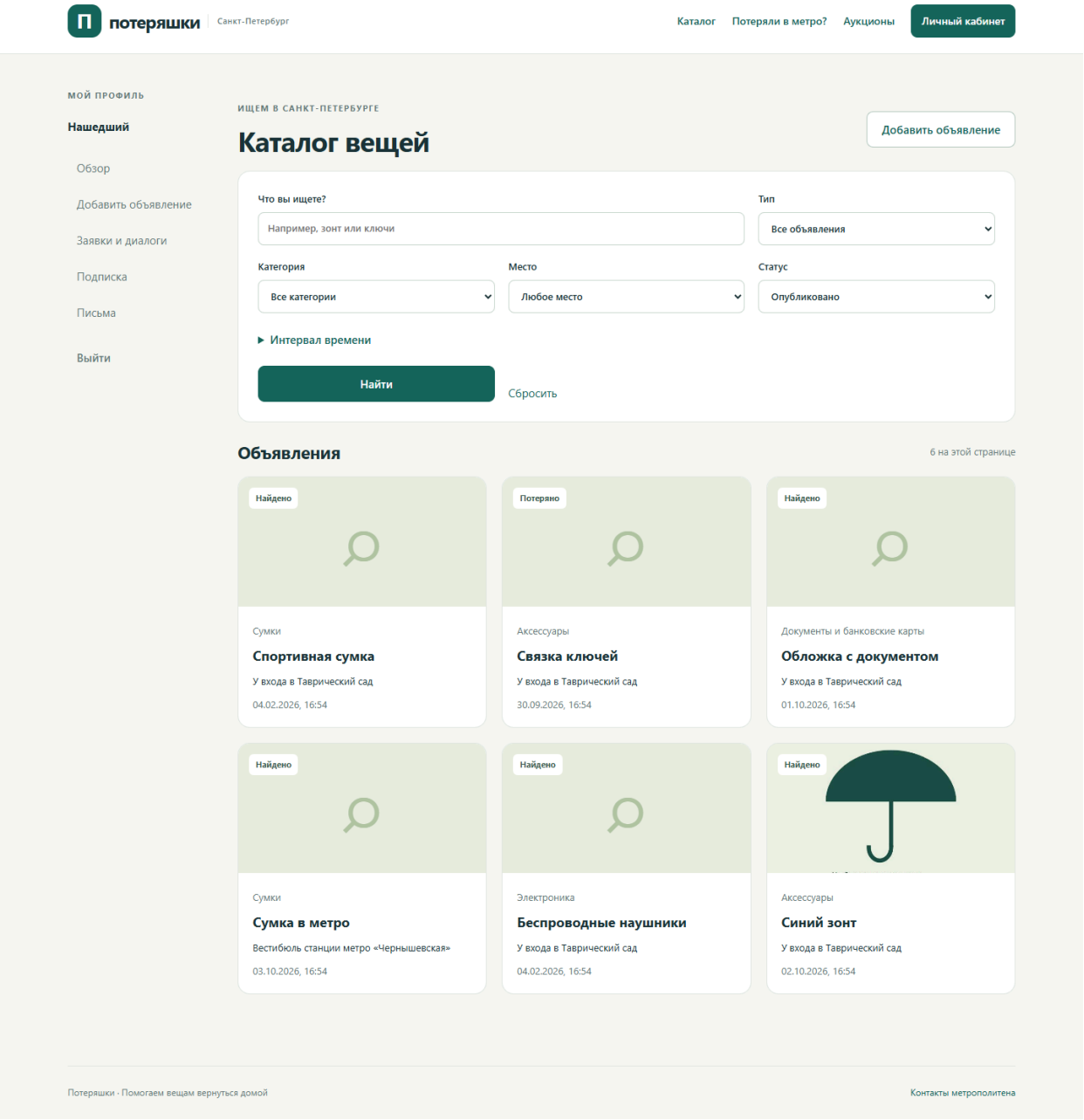


Рисунок 17 — Каталог объявлений

Редактор разделяет публичное описание и закрытые признаки. После сохранения автор может загрузить фотографии и отправить черновик на модерацию. Изменение опубликованного объявления требует повторной

проверки согласно правилам предыдущего этапа. Дата и время вводятся по часовому поясу Europe/Moscow.

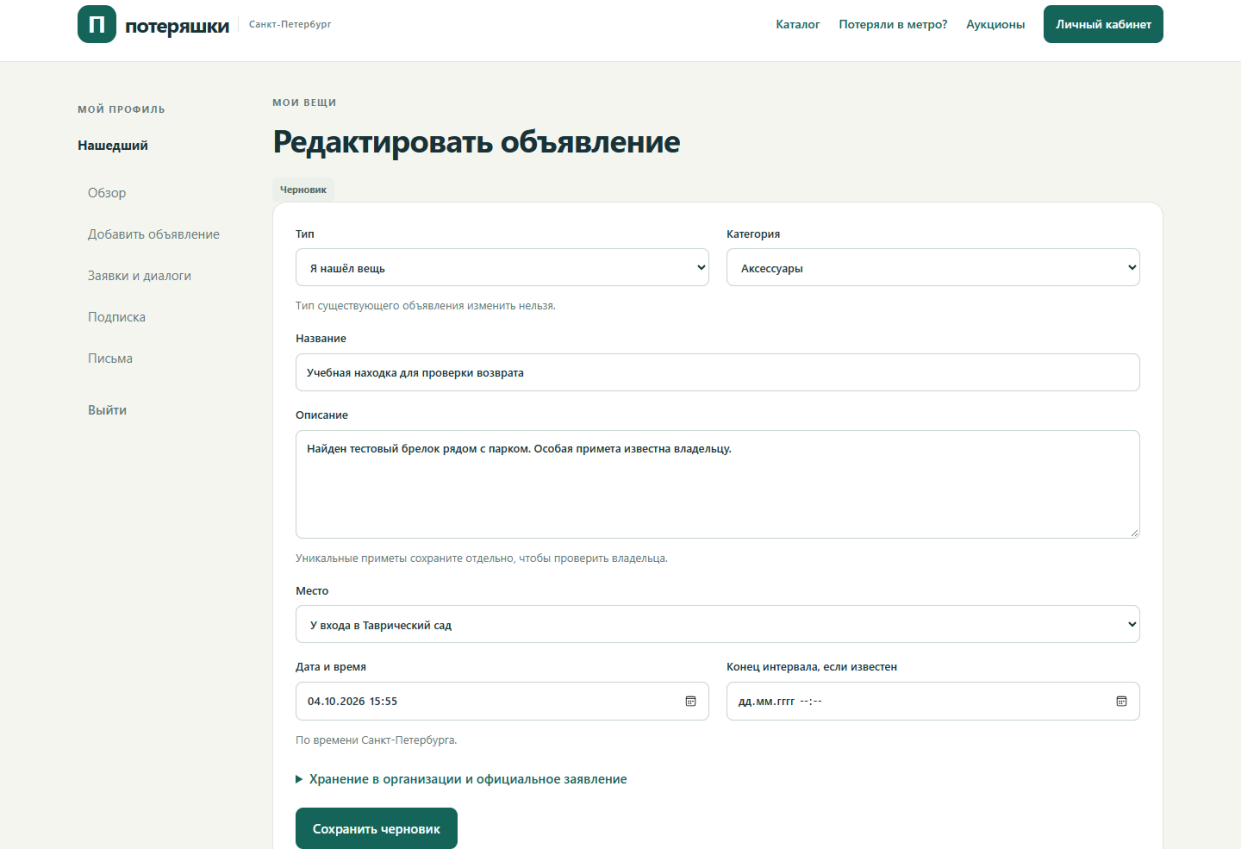


Рисунок 18 — Редактор объявления

Модератор рассматривает отдельные очереди. Для проверки профиля, допуска к продаже и разрешения спора вводится мотивированное решение. Проверка не позволяет сотруднику одобрить собственное объявление. Изменение ролей и тарифов доступно администратору.

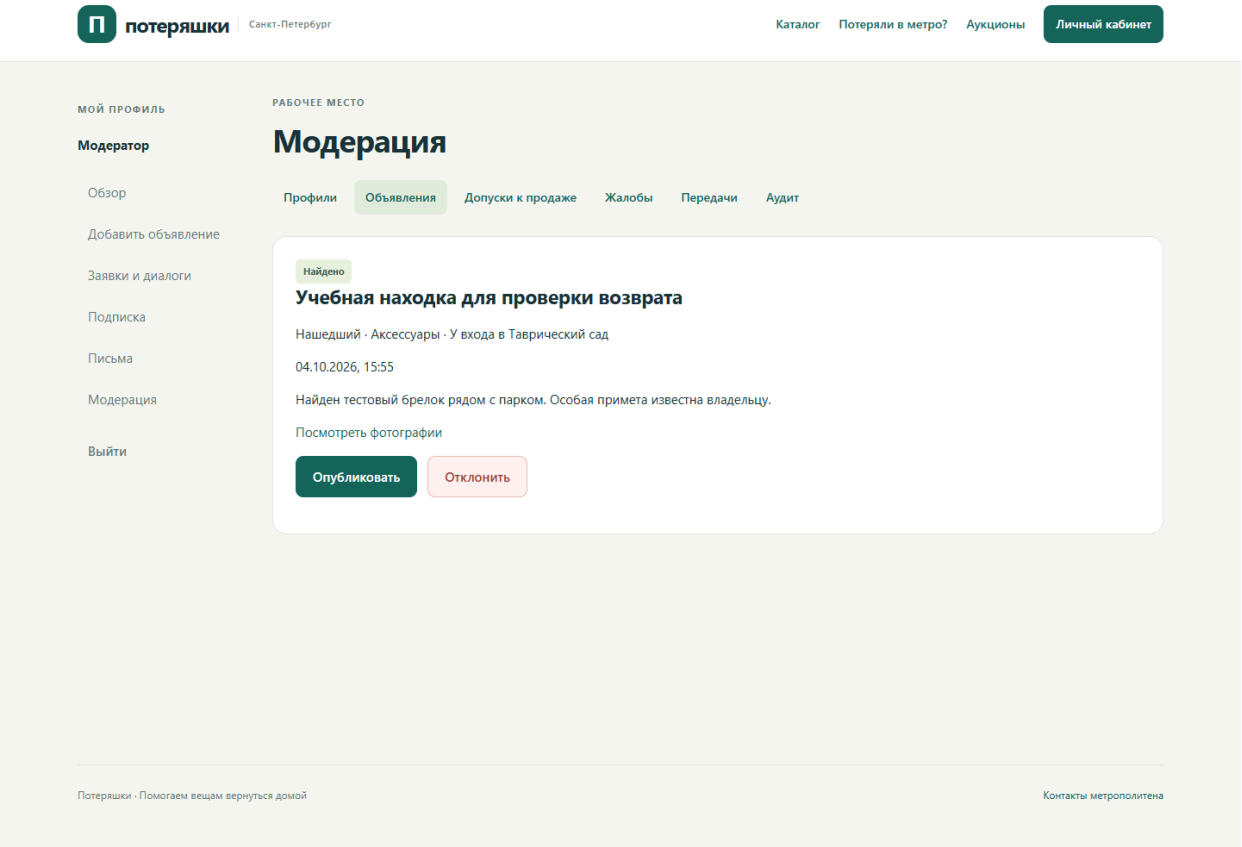


Рисунок 19 — Очередь объявлений модератора

Диалог доступен участникам заявки. Доказательства владения не выводятся в публичной карточке. После резервирования карточка заявки показывает два независимых подтверждения. Одно нажатие не завершает передачу; окончательное состояние устанавливает функция базы данных.

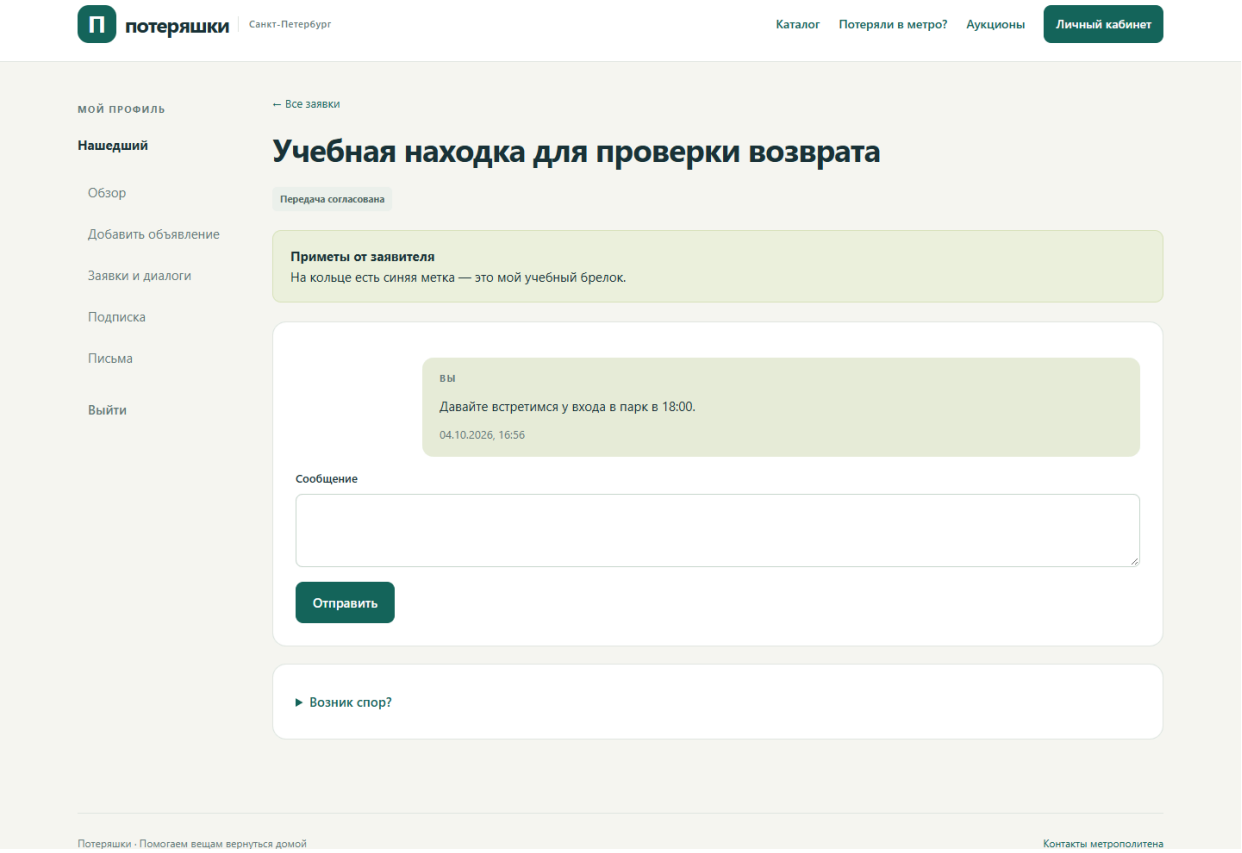


Рисунок 20 — Диалог о возврате

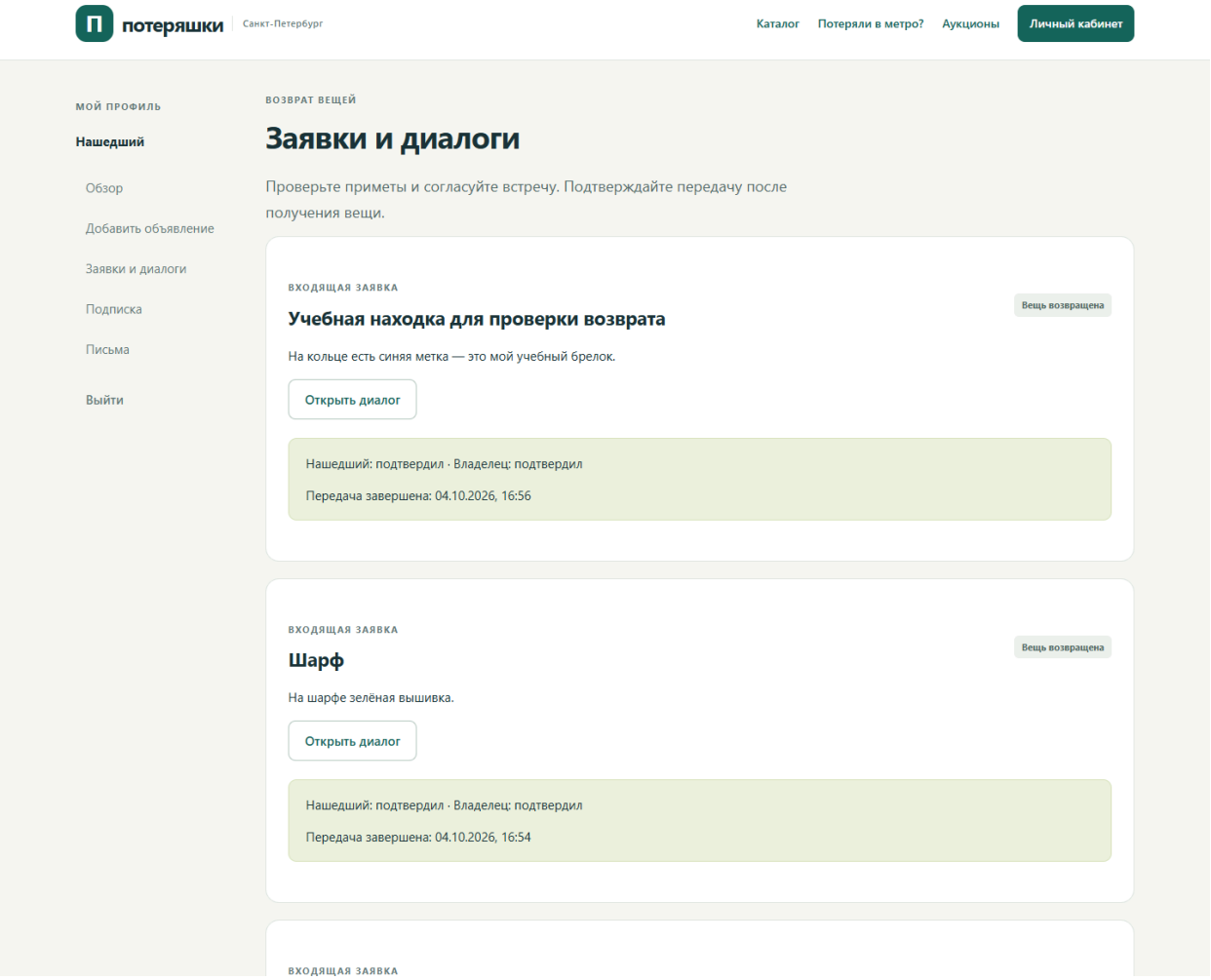


Рисунок 21 — Подтверждённая передача

Карточка аукциона показывает начальную цену, текущую ставку, шаг, начало и окончание торгов. Форма не показывается продавцу. Сервер повторно проверяет ограничения при отправке запроса; сохранённая или изменённая вручную форма не обходит проверки PostgreSQL.

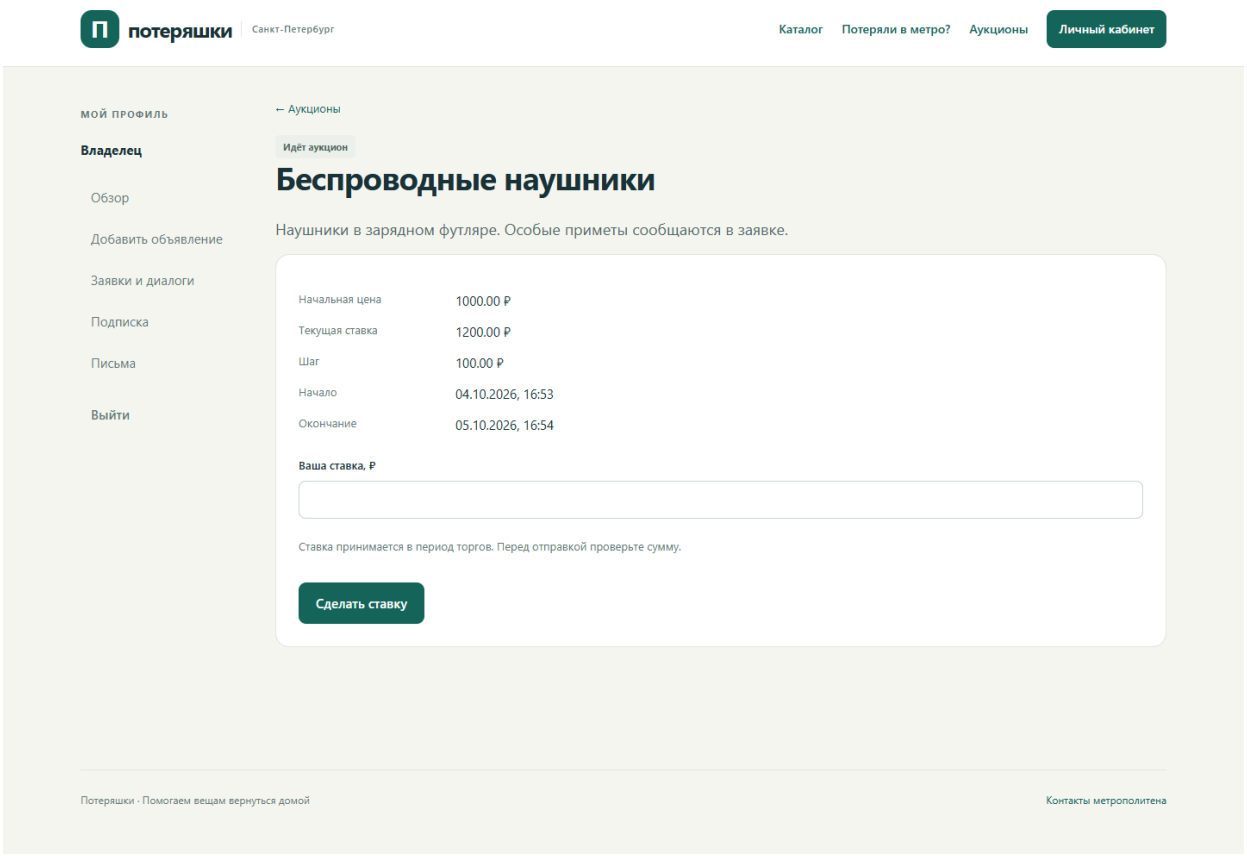


Рисунок 22 — Карточка аукциона

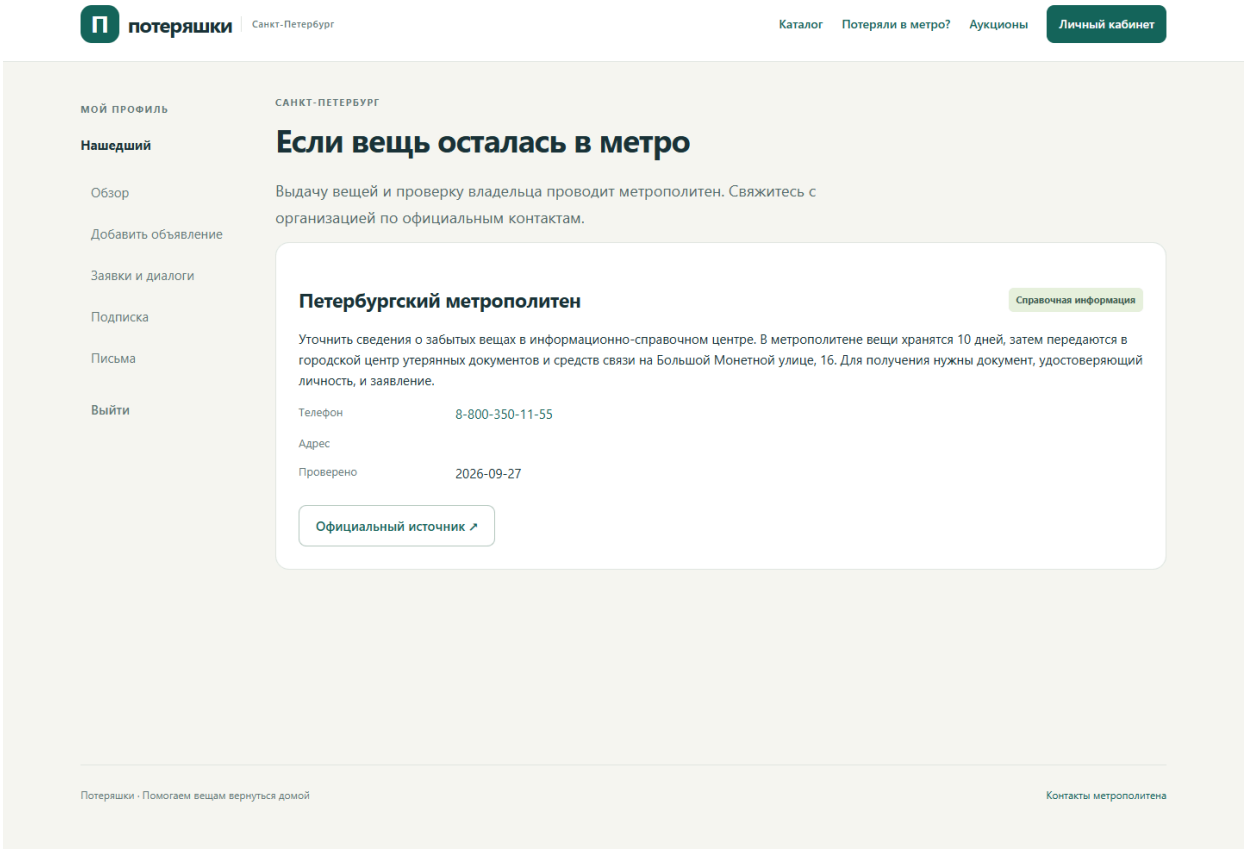


Рисунок 23 — Инструкция по обращению в метрополитен

Администратор видит пользователей и роли, управляет новыми тарифами и обновляет официальные контакты. Закрытие тарифа не меняет условия уже созданных заказов. При отзыве роли проверка доступа учитывает актуальные данные базы.

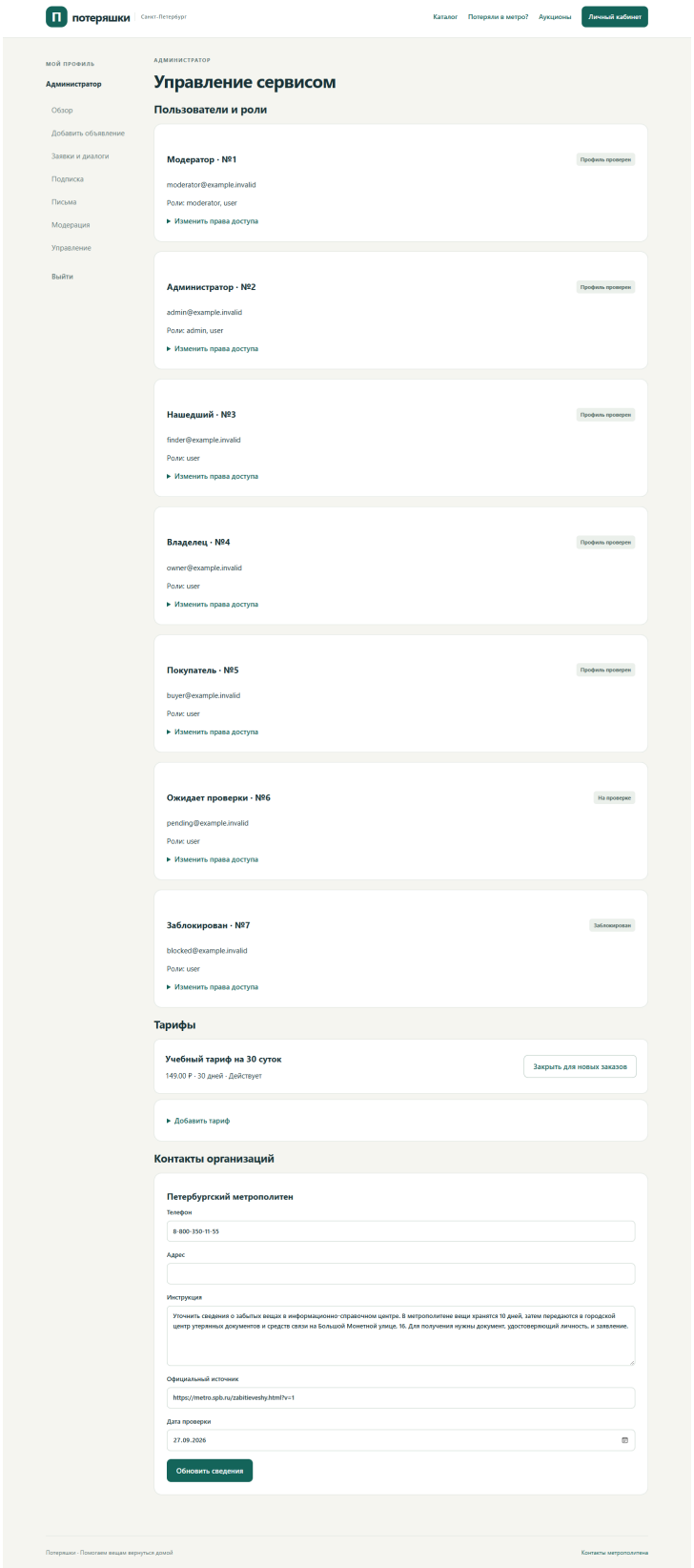


Рисунок 24 — Управление сервисом

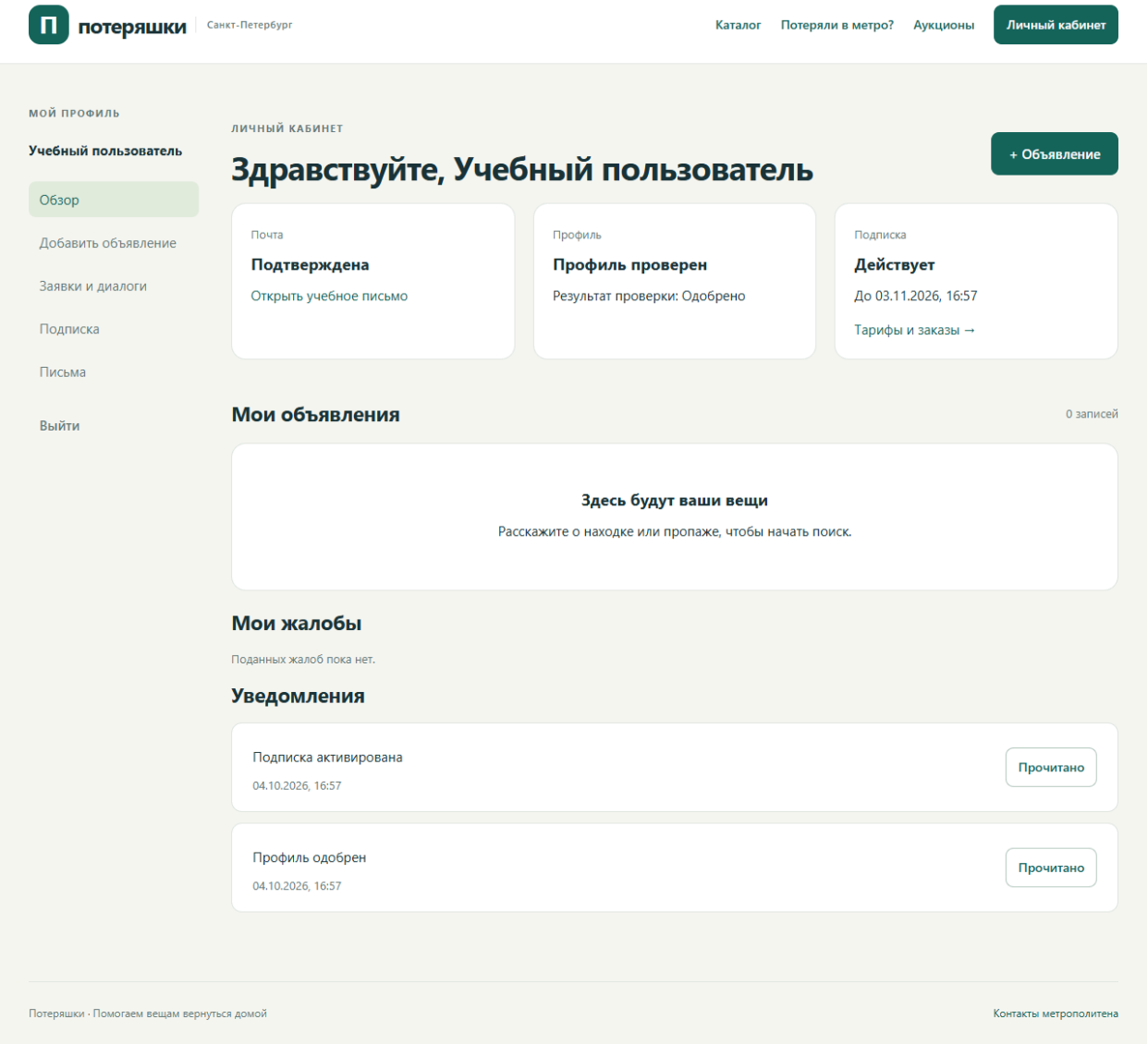


Рисунок 25 — Личный кабинет после учебной оплаты

При ширине 390 пикселей карточки и формы выстраиваются в одну колонку, меню переносится на несколько строк. Поля имеют подписи и видимый фокус; минимальная высота полей ввода и основных кнопок — 44 пикселя. Проверка на этой ширине не заменяет проверку всех устройств и средств доступности.

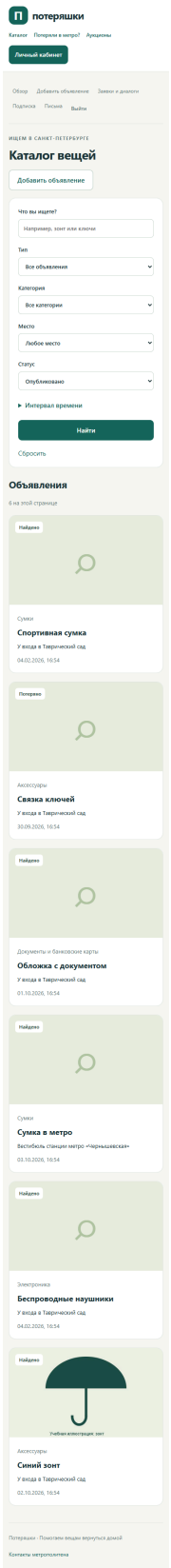


Рисунок 26 — Каталог на узком экране

22. Доступ и обработка данных

22.1. Сеансы и защита форм

WebSessions проверяет пароль BCrypt и создаёт случайный refresh-токен. В PostgreSQL сохраняется только его SHA-256. Access JWT действует 15 минут; refresh-токен — 30 суток. Оба передаются в HttpOnly cookie с SameSite=Lax. На каждом запросе проверяются версия токена пользователя, блокировка, срок и отзыв сеанса, текущие роли. Обновление атомарно отзывает прежний refresh-токен. Выход и смена пароля прекращают действие ранее выпущенных сеансов.

Spring Security проверяет CSRF-токен изменяющих запросов. Thymeleaf добавляет его к формам POST. Политика CSP запрещает скрипты, внешние стили и встраивание приложения во фрейм. Referrer-Policy не передаёт адрес страницы с одноразовым токеном сторонним сайтам. В публичном размещении требуются HTTPS и COOKIE_SECURE=true; учебный запуск выполняется на loopback через SSH-туннель. Секрет JWT можно задать переменной JWT_SECRET; при отсутствии создаётся случайный ключ на время запуска.

Пять неудачных попыток входа на один адрес в 15-минутном окне блокируют дальнейшие попытки до окончания окна. Счётчик находится в памяти одного процесса, поэтому перезапуск его сбрасывает; распределённая защита входа в этой версии не реализована.

22.2. Почта и вложения

MAIL_MODE=demo сохраняет учебные письма в памяти и показывает их только авторизованному получателю. При регистрации новый пользователь входит в собственный кабинет и открывает подтверждение. Публичный запрос восстановления всегда возвращает одинаковый результат и не раскрывает одноразовый токен. Полноценное восстановление забытого пароля без действующего входа требует MAIL_MODE=smtp и настроенного SMTP-сервера; учебный ящик для этого не заменяет внешнюю почту.

SMTP-адаптер использует STARTTLS и получает реквизиты из окружения; подключение к внешнему почтовому серверу не проверялось. Учебные письма исчезают после перезапуска. Платёжный адаптер работает

без списания средств, что указано на кнопке оплаты. Сумма берётся из сохранённого заказа.

PrivateFiles хранит файлы вне каталога статических ресурсов. При загрузке фотографий проверяются сигнатура JPEG/PNG, размер до 5 МБ и разрешение до 16 миллионов пикселей. Изображение декодируется и сохраняется заново без исходных метаданных. Имя формируется из UUID; путь проверяется на выход из корневой папки и символические ссылки. При отказе базы новый файл удаляется.

Подтверждение допуска принимает PDF либо изображение. PDF проверяется по сигнатуре и выдаётся как скачиваемое вложение, а не встроенная страница. Антивирусная проверка и полная проверка структуры PDF не реализованы. Документ доступен заявителю и модератору. Частные ответы не кешируются. В тестовом наборе старые ключи demo/ соответствуют явно помеченным учебным вложениям из закрытых ресурсов приложения; они не являются юридическими документами.

Файлы хранятся в закрытом локальном каталоге. MinIO не подключён; механизм восстановления файлов и автоматическая уборка объектов после аварийного завершения процесса не реализованы.

22.3. Фоновые операции

WebJobs каждые 30 секунд вызывает существующую процедуру закрытия истёкших аукционов и доставляет события Outbox во внутренние уведомления. Действия выполняются через предметные сервисы. Ошибка оставляет событие для следующего прохода. Планировщик отключается в интеграционных проверках, чтобы тестовые сценарии не изменялись параллельно.

Завершение торгов создаёт в PL/pgSQL одну заявку победителя, диалог и передачу. Победитель и продавец видят дело в /claims и отдельно подтверждают фактическую передачу. Отмена после первого подтверждения и односторонняя отмена результата аукциона запрещены. Жалоба из диалога относится к находке и доступна участнику при истёкшей подписке; модератор теряет доступ к чужому диалогу после закрытия дела. Получатель сообщения, автор проверенного профиля и автор рассмотренной жалобы получают внутренние

уведомления. Истёкший последний период подписки уведомляет один раз, без ложного события при активном продлении.

23. Проверка веб-приложения

23.1. Условия проверки

JUnit и MockMvc проверяют реальные сервисы и PostgreSQL через SSH-туннель. Создаются временные таблицы lf3check_; уже существующий набор с этим префиксом не принимается. После проверки набор удаляется, сравниваются исходные объекты схемы и значения остальных последовательностей. Пароли подключения не записываются в отчёт и репозиторий.

Браузерная проверка выполняется Playwright for Java в установленном Microsoft Edge. Запускается отдельный процесс приложения на свободном loopback-порту. Профили участников изолированы разными контекстами браузера. Используются тестовые адреса example.invalid и учебная оплата. Снимки в этом отчёте получены из работающего приложения.

Таблица 25 — Проверяемые группы сценариев

Группа	Проверка
Страницы	Главная, формы доступа, кабинет, каталог, редактор, заявки, аукционы и служебные очереди
Полномочия	Анонимный доступ, неоплаченный профиль, чужой редактор и диалог, служебные URL
Сеансы	HttpOnly/SameSite, отзыв при выходе и смене пароля, ротация refresh, актуальные роли
Формы	Отказ без CSRF, экранирование HTML, отсутствие секретов в публичных проекциях
Бизнес-процессы	Ставка через MVC и функцию БД; передача победителю; подтверждение при истёкшей подписке; запрет отмены после подтверждения
Жалобы и уведомления	Собственное решение в кабинете; доступ сотрудника только при открытой жалобе; уведомления без раскрытия текста диалога; окончание подписки без повторов
Файлы	Реальный PNG, повреждённые PNG/JPEG, подмена MIME/имени, SVG, размер и выход из каталога

Группа	Проверка
Браузер	Создание и фото, публикация, заявка, диалог, два подтверждения, жалоба и её рассмотрение, ставка, регистрация и подписка
Узкий экран	Каталог при ширине 390 пикселей и отсутствие горизонтального переполнения

Пройдены 113 тестов приложения и 8 тестов Java-инструментов. Протоколы находятся в docs/part4/validation и docs/part3/validation; результаты по классам тестов приведены в tests.json, журналы прогонов — в integration.txt и browser.txt. Нагрузочные испытания, проверка RPO/RTO и испытания внешних почтового и платёжного сервисов не проводились.

24. Демонстрация и итоговые материалы

Приложение размещается в собственном каталоге poteryashki-course на helios, подключается к таблицам lf_ схемы s465826 базы studs. JVM ограничена 64–256 МиБ. Веб-сервер слушает только 127.0.0.1:18081. Для доступа с рабочей машины используется SSH-туннель. Другая лабораторная не включается в состав установки.

Итоговый отчёт этапов 1–4 находится в docs/part1-4/report.md и report.pdf. К защите подготовлены презентация в PDF и HTML и сценарий демонстрации в presentation/defense.md.

Реализованы страницы для всех групп прецедентов первого этапа. Уровень представления использует существующие транзакции и функции БД. Система позволяет пройти путь от регистрации и проверки профиля до публикации, возврата вещи либо продажи с проверенным основанием. Учебные адаптеры и непроверенные эксплуатационные требования указаны отдельно.

В текущей версии отсутствуют автоматическое резервное копирование и восстановление, обезличивание профиля и единый идентификатор HTTP-запроса. Интерфейс проверен в Edge на компьютере и при ширине 390 px; испытания в Chrome и Firefox не проводились. Подключение MinIO и платёжного провайдера остаётся задачей дальнейшей разработки.

Источники четвёртого этапа

1. Spring Security. CSRF: https://docs.spring.io/spring-security/reference/servlet/exploits/csrf.html.

2. Spring Security. JWT: https://docs.spring.io/spring-security/reference/servlet/oauth2/resource-server/jwt.html.

3. Thymeleaf. Spring integration: https://www.thymeleaf.org/doc/tutorials/3.1/thymeleafspring.html.

4. Playwright for Java. Установка и работа с браузером: https://playwright.dev/java/docs/intro; https://playwright.dev/java/docs/browsers.